

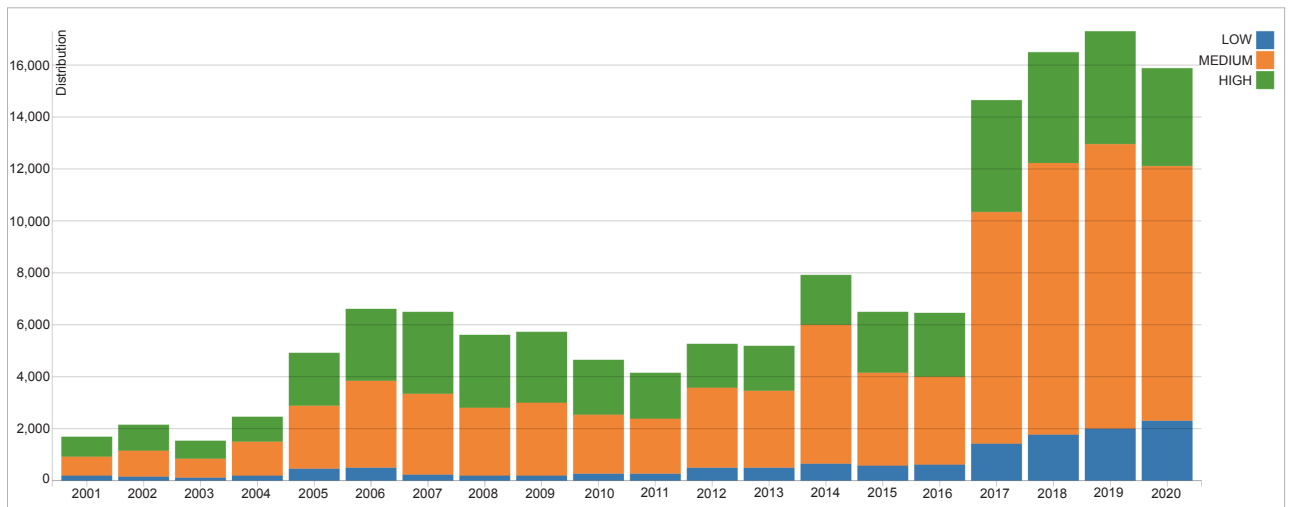


Figure 6: New CVEs added every year to NVD database

our own library. But those libraries can have security bugs. The OSS community fixes these vulnerabilities and releases a new version of those libraries.

The graph in Figure 6 tells us how many new common vulnerabilities and exposures (CVEs) are added to the national vulnerability database (NVD) alone every year.

Dependency checkers help to identify these security fixes in OSS libraries and notify developers to update the library or package. A dependency checker will identify the list of your application dependencies, and check it against the vulnerability database to see if any known vulnerability exists for the particular version being used (please refer to Figure 7).

Open source licence compliance

Open source libraries that we depend on for building our applications may come with different sets of licence requirements (Figure 8).

Licence restrictions may vary depending on how the library is used — whether the library is dynamically linked or modified source code is used as well (see Figure 9).

So the solution to the problem is to have an automated open source compliance (OSC) checker, which

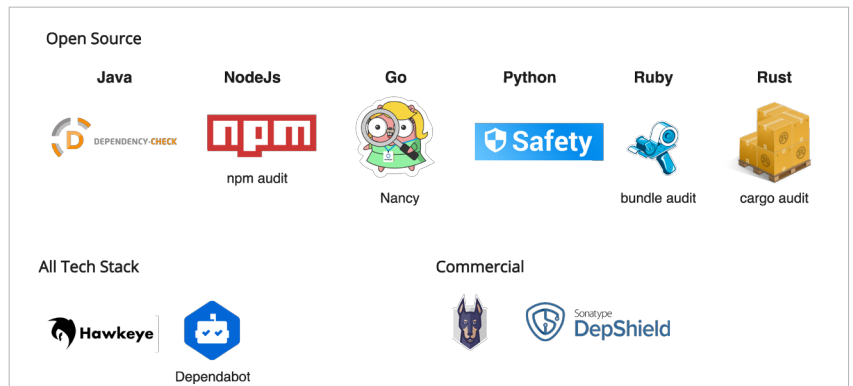


Figure 7: Tools | OSS dependency checkers

Permissive Licenses: BSD, MIT, Apache

- No Restrictions

Public Use Licenses: Mozilla (MPL), Eclipse (EPL)

- Publish modified code, Include in OSS disclosures

Non Permissive Licenses: GPLv2, LGPLv2.1, GPL v3

- GPL: Publish all code of your entire application/any derived work
- LGPL: Publish all code of your entire application/any derived work under
- Requires complete legal review of those licenses



Figure 8: OSS licence types

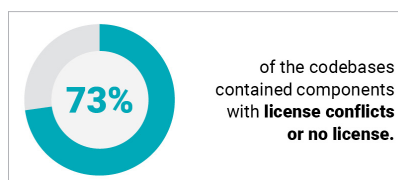


Figure 9: OSS licence violations report
(<https://www.synopsys.com/blogs/software-security/5-open-source-trends-2020-ossra/>)

will scan all the dependencies and identify the licence associated with it. You can make a list of approved licences and tools based on your organisation's standards. The licence checker will compare both the data and identify any dependency that violates the organisation's policy (Figure 10).